

Dquez Carr
MCY 650
Reading Assignment
September, 2024

1. What is the difference between connectionless communication and connection-oriented communication?

Connection-oriented communication: Utilizes TCP and is a more orderly way of data exchange. It's good for transmitting large files and communicating across network boundaries. Senders will reach out to form a connection to see if the Recipient is available and willing to set up a data channel before data is transmitted. Once the data exchange begins, the two systems will continue to communicate to ensure flow control. Retransmission is possible if data is lost. All this is done through the 6 header flags and the three-way handshake.

Connectionless communication: Utilizes UDP and is a low-overhead, simple, and fast transport protocol. The Sender is moving small amounts of data (one or two packets) and usually within the network structure (not across the internet). The Sender doesn't care if the Recipient has the bandwidth to receive the data nor does it care if the Recipient receives the data 'Fire and Forget' communication style.

2. What is the purpose of sequence number in TCP header?

Sequence number: A pseudorandom number that helps maintain the legitimacy and uniqueness of the session. The sequence number plays a role in data exchange flow control by allowing the Recipient to Acknowledge data receipt, Track data order, Prevent duplicates, and Handle data loss/ retransmission.

3. What is the max number of TCP ports? Similarly, how many UDP ports are there?

No port is exclusively allocated to either TCP or UDP protocol. Most ports are usable by both, depending on the needs of the application and service. Port assignments are overseen by the Internet Assigned Numbers Authority (IANA) and they span from **0 to 65,535**.

4. What are the well known port numbers for the following protocols: Telnet, FTP, SSH, DNS, DHCP, HTTP, HTTPS?

Telnet:23, FTP:20/21, SSH:22, DNS:53, DHCP:67/68, HTTP:80, HTTPS:443

5. Say you have an address of 193.24.15.49 and the subnet mask is 255.255.252.0, what is the network address?

Network address: 193.24.12.0

6. What are the steps in the scanning phase?

Check for live systems: Using ping sweep to find what boxes are alive on your network subnet.

Check for open ports: Once you know which IP addresses are active, find what ports they are listening on.

Scan beyond IDS: Sometimes your scanning efforts need to be altered to avoid those pesky IDS

Perform 'Banner Grabbing': Banner Grabbing and OS fingerprinting will tell you what OS is on the machines and which services they are running.

Scan for vulnerabilities: Perform a more focused look at the vulnerabilities these machines have not patched yet.

Draw network diagrams: A good network diagram will display all the logical and physical pathways to targets you might like.

Prepare proxies: This obscures your efforts to keep you hidden.

7. What are the 7 generic scan types for port scanning?

Full connect Scan 'TCP connect scan' -sT: Runs through a full connection (three-way handshake) on all ports. Not very stealthy.

SYN Scan 'half-open scan' -sS: Only SYN packets are sent to ports (no completion of the three-way handshake)

FIN Scan -sF: The reverse of a SYN scan. It runs the communication set-up in reverse, sending a packet with the FIN flag set. Closed ports will respond with RST, whereas open ports will not respond at all.

XMAS Scan -sX: Sends a packet with all flags turned on. Closed ports will respond with RST, whereas open ports will not respond at all.

ACK Scan 'mainly for Unix/Linux' -sA: ACK scans make use of ICMP destination unreachable messages (Firewall is preventing ICMP message- Type 13) to determine what ports may be open on a firewall.

IDLE Scan -sI: This uses a spoofed IP address to elicit a port response during a scan. It uses a SYN flag and monitors response as with a SYN scan. This is designed for stealth.

NULL Scan -sN: The opposite of a XMAS scan. The Null scan sends packets with no flags set. Responses will vary, depending on the OS and Version, but NULL scans are designed for Unix/Linux machines.

8. Explain SYN Scan and XMAS Scan.

SYN Scan 'Half-open': Is a stealth scan, Initial flag set is 'SYN', Open port response is 'SYN/ACK', Closed port response is 'RST'. Not a completion of the three-way handshake, and may be picked up by IDS despite stealth.

XMAS Scan: Initial flag set is 'FIN/URG/PSH', Open port response is 'No response', Closed port response is 'RST/ACK'. Does Not work on Windows machines

9. Give concrete commands for performing the following scans: SYN scan, XMAS scan, and TCP scan. Please use one of your class VM to show the scanning result (screenshot will be fine).

SYN Scan:

```
root@nku-kali:~# nmap -sS scanme.nmap.org
Starting Nmap 7.80 ( https://nmap.org ) at 2024-09-07 00:43 EDT
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.056s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 992 closed ports
PORT      STATE      SERVICE
22/tcp    open      ssh
25/tcp    filtered  smtp
80/tcp    open      http
445/tcp   filtered  microsoft-ds
465/tcp   filtered  smtps
6881/tcp  filtered  bittorrent-tracker
9929/tcp  open      nping-echo
31337/tcp open      Elite
Nmap done: 1 IP address (1 host up) scanned in 2.06 seconds
```

XMAS Scan:

```
root@nku-kali:~# nmap -sX scanme.nmap.org
Starting Nmap 7.80 ( https://nmap.org ) at 2024-09-07 00:45 EDT
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.00075s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 996 closed ports
PORT      STATE      SERVICE
25/tcp    open|filtered smtp
445/tcp   open|filtered microsoft-ds
465/tcp   open|filtered smtps
6881/tcp  open|filtered bittorrent-tracker
Nmap done: 1 IP address (1 host up) scanned in 1.38 seconds
```

TCP Scan:

```
root@nku-kali:~# nmap -sT scanme.nmap.org
Starting Nmap 7.80 ( https://nmap.org ) at 2024-09-07 00:46 EDT
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.056s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 992 closed ports
PORT      STATE      SERVICE
22/tcp    open      ssh
25/tcp    filtered  smtp
80/tcp    open      http
445/tcp   filtered  microsoft-ds
465/tcp   filtered  smtps
6881/tcp  filtered  bittorrent-tracker
9929/tcp  open      nping-echo
31337/tcp open      Elite
Nmap done: 1 IP address (1 host up) scanned in 2.05 seconds
```

10. What is banner grabbing?

Banner grabbing is a part of enumeration techniques, the tactic involves sending an unsolicited request to an open port to see what, if any, default message (banner) is returned. The returned banner—which could be an error message, an HTTP header, or a login message—could point to a potential vulnerability that a hacker could exploit, depending on which version of the application is running on the port.

EC-Council's scanning methodology phases

Why is UDP a low-overhead protocol?

Why is UDP good for moving small amounts of data?

Connection-oriented vs connectionless communication

What are the purposes of 6 flags in TCP header?

What are the TCP port states? What command do you use to see TCP connection and port states?

What protocol does ping command use?

Common ICMP message types

Common usage of nmap

Understand common nmap port scanning command line switches

Understand nmap generic scan types

What is banner grabbing?